



## Table of Contents

|                                                                              |   |
|------------------------------------------------------------------------------|---|
| 1 Penetration Test Report — Brunnhofer Bau AG.....                           | 1 |
| 1.1 1. Executive Summary.....                                                | 2 |
| 1.1.1 Summary of findings.....                                               | 2 |
| 1.2 2. Scope & Methodology.....                                              | 3 |
| 1.2.1 2.1 In-scope assets.....                                               | 3 |
| 1.2.2 2.2 Out of scope.....                                                  | 3 |
| 1.2.3 2.3 Method.....                                                        | 3 |
| 1.3 3. Findings.....                                                         | 4 |
| 1.3.1 F-01 — Internet-exposed RDP without NLA/MFA.....                       | 4 |
| 1.3.2 F-02 — Unconstrained Kerberos delegation leading to domain compromise. | 4 |
| 1.3.3 F-03 — SMB signing not required (NTLM relay / MITM).....               | 5 |
| 1.3.4 F-04 — Weak / obsolete TLS configuration on public portal.....         | 6 |
| 1.3.5 F-05 — LLMNR / NBT-NS poisoning enables credential capture.....        | 6 |
| 1.4 4. Remediation Plan.....                                                 | 7 |
| 1.5 5. Appendix A — Tools & Techniques.....                                  | 7 |
| 1.6 6. Appendix B — Rules of Engagement (summary).....                       | 7 |

## 1 Penetration Test Report — Brunnhofer Bau AG

### External & Internal Infrastructure Assessment

Prepared by: Halden Security GmbH — Offensive Security · Zurich Prepared for:  
Brunnhofer Bau AG Engagement ref: HS-2026-0417 Classification: CONFIDENTIAL  
Report date: 14 March 2026 Test window: 24 February 2026 – 06 March 2026

Authors: R. Kessler (Lead), P. Oduya (Consultant) Reviewed by: M. Halden (Principal)

---



## 1.1 1. Executive Summary

Halden Security GmbH was engaged by Brunnhofer Bau AG (“Brunnhofer”) to perform a combined external and internal infrastructure penetration test of the company’s corporate network, remote-access services, and internet-facing systems. The objective was to determine whether an attacker — either an anonymous actor on the internet or a malicious insider with a foothold on the office LAN — could compromise sensitive project data, disrupt business operations, or gain administrative control of the Active Directory domain.

Testing was performed against the agreed scope between 24 February and 06 March 2026 using a grey-box approach. Halden was provided with a network diagram and one standard-user domain account for the internal phase; no administrative credentials were shared in advance.

**Overall risk rating: HIGH.**

The assessment identified five noteworthy findings, two of which are rated High severity. The most significant issue is an internet-exposed Remote Desktop (RDP) service on a project-file server that permits direct logon from any source address and lacks network-level authentication and multi-factor authentication. Combined with a weak password policy observed during the internal phase, this exposure would plausibly allow an external attacker to obtain an interactive session on the corporate network. Halden was able to escalate from a standard domain user to Domain Admin during the internal phase in under three hours, primarily by abusing unconstrained Kerberos delegation and recovering credentials from a legacy service account.

The good news: none of the identified issues require complex or expensive remediation. The highest-risk items can be closed within days by removing RDP from the internet, enforcing SMB signing, and rotating and constraining a small number of service accounts. Brunnhofer’s patch hygiene on workstations was notably better than average.

### 1.1.1 Summary of findings

| #    | Finding                                                  | Severity | CVSS 3.1 |
|------|----------------------------------------------------------|----------|----------|
| F-01 | Internet-exposed RDP without NLA/MFA                     | High     | 8.1      |
| F-02 | Unconstrained Kerberos delegation<br>→ domain compromise | High     | 8.8      |
| F-03 | SMB signing not required (relay/MITM)                    | Medium   | 6.5      |
| F-04 | Weak / obsolete TLS                                      | Medium   | 5.9      |



| #    | Finding                                                                   | Severity | CVSS 3.1 |
|------|---------------------------------------------------------------------------|----------|----------|
| F-05 | on public web portal<br>LLMNR/NBT-NS poisoning enables credential capture | Medium   | 6.3      |

## 1.2 2. Scope & Methodology

### 1.2.1 2.1 In-scope assets

**External (internet-facing):** - portal.brunnhofer.example — 203.0.113.20 (project extranet, IIS) - mail.brunnhofer.example — 203.0.113.24 (Exchange, OWA/EWS) - vpn.brunnhofer.example — 203.0.113.28 (SSL VPN) - 203.0.113.16/28 (public /28 range, full port sweep)

**Internal (grey-box, on-site + jump host):** - 10.40.0.0/16 corporate LAN - Active Directory domain corp.brunnhofer.local (2 DCs) - File server BRU-FS01, project server BRU-PRJ01

### 1.2.2 2.2 Out of scope

- Any denial-of-service or load/stress testing
- Social engineering and physical intrusion
- The SaaS-hosted ERP (brunnhofer.eu.sap-hosted.example) — third-party owned
- OT / site-office construction equipment networks

### 1.2.3 2.3 Method

The engagement followed the PTES and OWASP methodologies and was mapped to MITRE ATT&CK where relevant. Phases:

1. **Reconnaissance & enumeration** — passive OSINT, DNS, port and service discovery.
2. **Vulnerability identification** — authenticated and unauthenticated scanning, manual verification (all automated findings were manually confirmed to eliminate false positives).
3. **Exploitation** — controlled exploitation to demonstrate impact.
4. **Post-exploitation & lateral movement** — internal phase only, within rules of engagement.
5. **Reporting** — this document.

Severity ratings use CVSS v3.1 base scores, adjusted for business context.



## 1.3 3. Findings

### 1.3.1 F-01 — Internet-exposed RDP without NLA/MFA

- **Severity:** High
- **CVSS 3.1:** 8.1 — AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N
- **Affected host:** BRU-PRJ01 — 203.0.113.22:3389

**Impact.** The project file server exposes Remote Desktop directly to the internet. Network Level Authentication (NLA) is disabled, meaning the logon UI is presented pre-authentication, and no multi-factor authentication is enforced. An attacker can perform unlimited credential-guessing (see also weak password policy under F-02 context) and, once valid credentials are obtained, gains a full interactive Windows session on a server holding project drawings and contract documents. This is a common initial-access vector for ransomware operators.

**Evidence.** External scan of the public /28 returned:

```
203.0.113.22 3389/tcp open  ms-wbt-server
| rdp-ntlm-info:
|   Target_Name: CORP
|   NetBIOS_Domain_Name: CORP
|   DNS_Domain_Name: corp.brunnhofer.local
|   Product_Version: 10.0.17763 (Server 2019)
|   NLA: disabled
```

Halden confirmed the logon screen was reachable and that account lockout was not triggered after 30 attempts against a test account (with client consent).

**Remediation.** - Remove RDP (3389/tcp) from all internet-facing interfaces immediately. Place behind the VPN or a dedicated RD Gateway. - Enforce NLA and require MFA for all remote interactive logons. - Implement account lockout / rate limiting and alert on brute-force patterns.

---

### 1.3.2 F-02 — Unconstrained Kerberos delegation leading to domain compromise

- **Severity:** High
- **CVSS 3.1:** 8.8 — AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
- **Affected host:** BRU-APP02 (10.40.12.19), domain corp.brunnhofer.local



**Impact.** The application server BRU-APP02 was configured with unconstrained Kerberos delegation. Starting from the single standard-user account provided, Halden coerced authentication from a Domain Controller to BRU-APP02 and captured a TGT for the DC computer account, enabling a DCSync and full extraction of domain credential hashes — i.e. complete domain compromise. Total elapsed time from standard user to Domain Admin: approximately 2 hours 45 minutes.

**Evidence (sanitised).**

[\*] Found DC \$ TGT in memory of BRU-APP02  
[\*] Executing DCSync for corp\krbtgt ... OK  
[\*] corp\Administrator:aad3b435....31d6cfe0... (redacted)

A legacy service account svc\_backup was also found with a 2019-era password (never rotated) and PASSWD\_NOTREQD set.

**Remediation.** - Remove unconstrained delegation from BRU-APP02; use constrained (resource-based) delegation only where required. - Add all privileged and service accounts to the Protected Users group and mark sensitive accounts “Account is sensitive and cannot be delegated”. - Rotate svc\_backup and all service-account passwords; enforce ≥25-character managed passwords (gMSA where possible). - Deploy DC patches mitigating authentication coercion.

---

### 1.3.3 F-03 — SMB signing not required (NTLM relay / MITM)

- **Severity:** Medium
- **CVSS 3.1:** 6.5 — AV:A/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N
- **Affected hosts:** 41 internal hosts including BRU-FS01, multiple workstations

**Impact.** SMB signing was not required across the majority of the internal estate. An attacker on the LAN can perform NTLM relay attacks — capturing authentication (see F-05) and relaying it to unsigned SMB hosts to execute commands in the context of the victim, without ever cracking a password.

**Evidence.**

SMB 10.40.4.11 BRU-FS01 signing:False SMBv2  
SMB 10.40.7.63 WKS-1042 signing:False SMBv2  
... (41 hosts, signing:False)

**Remediation.** - Enforce “Microsoft network server: Digitally sign communications (always)” via GPO on all hosts. - Disable NTLM where feasible; prefer Kerberos. - Enable Extended Protection for Authentication (EPA) on internal web services.

---



### 1.3.4 F-04 — Weak / obsolete TLS configuration on public portal

- **Severity:** Medium
- **CVSS 3.1:** 5.9 — AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N
- **Affected host:** portal.brunnhofer.example — 203.0.113.20:443

**Impact.** The extranet portal supports TLS 1.0/1.1 and weak cipher suites (CBC, RSA key exchange without forward secrecy). This exposes client sessions to downgrade and, under favourable conditions, decryption of intercepted traffic. It also fails PCI/modern baseline requirements.

**Evidence.**

TLSv1.0 enabled

TLSv1.1 enabled

TLS\_RSA\_WITH\_3DES\_EDE\_CBC\_SHA (0x000a) weak

Certificate: SHA-256, valid, 2048-bit RSA (OK)

**Remediation.** - Disable TLS 1.0 and 1.1; require TLS 1.2+ (prefer 1.3). - Restrict to AEAD cipher suites with forward secrecy (ECDHE). - Enable HSTS with a suitable max-age.

---

### 1.3.5 F-05 — LLMNR / NBT-NS poisoning enables credential capture

- **Severity:** Medium
- **CVSS 3.1:** 6.3 — AV:A/AC:L/PR:N/UI:R/S:U/C:H/I:L/A:N
- **Affected scope:** Corporate LAN 10.40.0.0/16 (broadcast domains)

**Impact.** LLMNR and NBT-NS name resolution were enabled. By responding to failed name-resolution broadcasts, Halden captured NTLMv2 authentication material from multiple users. Several captured hashes were crackable offline within minutes due to weak passwords, and the material can also be relayed (see F-03).

**Evidence.** 6 unique NTLMv2 hashes captured in a 15-minute window; 2 cracked offline (passwords of the pattern Season+Year!).

**Remediation.** - Disable LLMNR (GPO: Turn off multicast name resolution) and NBT-NS across the estate. - Strengthen password policy; deploy a banned-password list and encourage passphrases/MFA.

---



## 1.4 4. Remediation Plan

| Priority        | Finding | Action                                                   | Effort | Target   |
|-----------------|---------|----------------------------------------------------------|--------|----------|
| P1 — Immediate  | F-01    | Remove internet RDP; enforce NLA + MFA                   | Low    | 48 hours |
| P1 — Immediate  | F-02    | Remove unconstrained delegation; rotate service accounts | Medium | 1 week   |
| P2 — Short term | F-03    | Enforce SMB signing via GPO                              | Low    | 2 weeks  |
| P2 — Short term | F-05    | Disable LLMNR/NBT-NS; password policy                    | Low    | 2 weeks  |
| P3 — Planned    | F-04    | Harden TLS on portal; enable HSTS                        | Low    | 30 days  |

A retest of P1 and P2 items is recommended within 30 days of remediation. Halden offers a complimentary verification retest of High findings within the engagement.

---

## 1.5 5. Appendix A — Tools & Techniques

- **Reconnaissance:** nmap 7.94, dnsx, amass, masscan
- **Vulnerability scanning:** Nessus Professional, testssl.sh
- **AD / internal:** BloodHound / SharpHound, NetExec (formerly CrackMapExec), Responder, Impacket (secretsdump, ntlmrelayx), Rubeus
- **Password cracking:** Hashcat (offline, isolated host)
- **Web / TLS:** Burp Suite Professional, sslscan

## 1.6 6. Appendix B — Rules of Engagement (summary)

- Testing restricted to agreed IP ranges and the internal grey-box account.
- No DoS, no data exfiltration beyond proof-of-access screenshots.
- Emergency contact: Brunnhofer IT Lead, available during test hours.



- All exploited access documented; no persistence left in place.

*This report is confidential and intended solely for Brunnhofer Bau AG. Findings reflect the state of the environment during the test window and may not account for subsequent changes.*